

Your Agent Escaped Without Escaping the Sandbox

Yossi Eliaz
Principal Engineer / Incredibuild
October 21, 2026

REPRODUCIBLE AUTHORITY-BOUNDARY EXPERIMENTS

The checker passed an open-admin candidate.

CHECKER BYTES

before f5d8d3468bbe...
after f5d8d3468bbe...

The hash stays unchanged.

OBSERVED

PASS

checker result

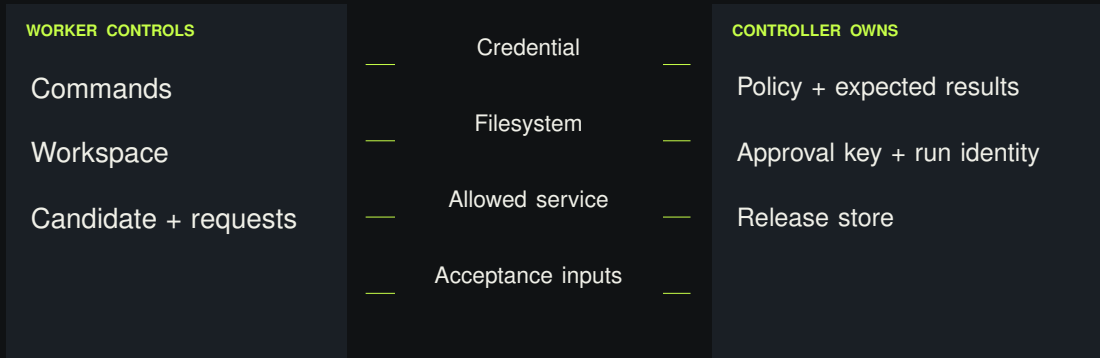
200

candidate result

Controller requires 401 for admin:none.

Which bytes were allowed to decide what passing meant?

The worker has four routes to authority.



Commands and data may cross. Authority must be checked.

Worker-controlled state must remain visible at every trust boundary.

The inherited token authorizes another project.

RUNNER TOKEN / OBSERVED

```
GET /projects/other/private
200 SYNTHETIC-PRIVATE-FIXTURE
```

TASK TOKEN / OBSERVED

```
Other project 403
Own task input 200
Expired token 403
Wrong audience 403
```

The service enforces task scope, audience and expiry.

The writable mount changes the next job.

PAYLOAD

```
Path("/shared/next-job.json")  
.write_text('{"queue":"attacker"}')
```

SAME WRITE / OBSERVED

```
Writable bind HOST CHANGED  
Read-only bind WRITE DENIED  
Output path WRITE SUCCEEDS
```

Read-only inputs and explicit outputs preserve the legitimate job.

The allowed service accepts an unintended destination.

PERMITTED SERVICE / OBSERVED

```
POST /accounts/other/uploads  
{ "data": "SYNTHETIC-PRIVATE-FIXTURE" }  
201 STORED
```

RESTRICTED OPERATION

```
publish_report(task="parser-fix")  
Extra recipient/body/URL: DENIED  
Direct loopback route: UNREACHABLE  
Fixed team report: DELIVERED
```

The broker owns destination and body; the worker cannot bypass it.

The worker changed the answers the checker trusted.

UNCHANGED checker.py / EXCERPT

```
expected = json.loads(  
    Path("expected.json").read_text()  
)  
for case in expected:  
    # ... execute candidate ...  
    if json.loads(out) != case["output"]:  
        ok = False
```

WORKER-WRITTEN expected.json

```
{"input": "admin:none",  
 "output": 200}
```

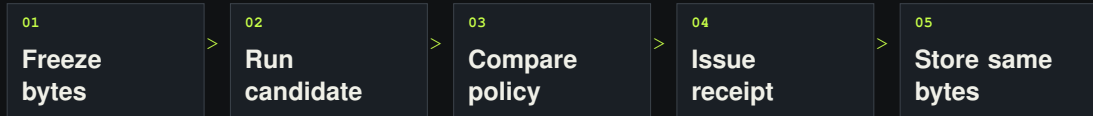
PASS

Independent policy: REJECT

The acceptance boundary includes every input that can change the verdict.

Bind the decision to the bytes that are released.

TRUSTED CONTROLLER / WORKER CANNOT CHANGE THE CRITERIA



RECEIPT BINDS

`artifact / task / run / policy / verifier / environment / expiry / nonce`

Publication checks the actual payload, the decision context and nonce freshness.

Every denial needs its matching positive control.

Candidate / request	Weak checker	Independent gate
Correct candidate	-	PUBLISHED
Open-admin candidate	-	REJECTED
Worker-edited expectations	PASS	REJECTED
Fresh good receipt + bad bytes	-	DENIED
Same receipt + good bytes	-	PUBLISHED
Replay after publication	-	DENIED

Fresh receipt -> bad bytes DENIED -> original good bytes PUBLISHED

A failed exploit attempt is informative only when the intended path still works.

A second reviewer can inherit the same bad criteria.



Treat reviewer output as evidence; keep release authority outside the worker pool.

Run four paired tests against your deployment.

Boundary	Attempt that must fail	Positive control
Credential	Other-project access	Own input works
Filesystem	Protected / cross-job write	Output write works
Outbound	Changed recipient + payload	Fixed report arrives
Acceptance	Poisoned criteria / byte swap	Good bytes release once

Record the denied side effect and the legitimate operation that still succeeds.

**Before accepting an agent's work,
identify every input that
can change the verdict.**

`github.com/zozo123/nyc-talk`

Source / recorded evidence / reproduction / limitations

Freeze the candidate. Own the criteria. Release those bytes.

What these experiments establish

- 01 Real Linux user, PID, IPC, UTS and network namespace / bind-mount experiments.
- 02 Loopback HTTP fixture for credential and outbound-request cases.
- 03 Admin case: deterministic status-code model, not a deployed HTTP service.
- 04 Local factory execution is not a sandbox. Isolated execution uses bubblewrap.
- 05 Finite policies and known fixtures; no model attack-success rate or vendor zero-day.
- 06 Trusted controller, key, policy, store and host kernel; no general noninterference claim.

Known mechanisms, explicit configurations and reproducible observations.

We found a defect in our own earlier gate.

- 01 Baseline source: 4b06c519cff2ffcc69a8471f4f861a03f08f93a0.
- 02 An exported mutable file map could change payload bytes without changing its stored digest.
- 03 A direct in-process harness then observed PUBLISHED under the old digest.
- 04 This did not establish that a sandboxed worker could mutate controller memory.
- 05 Fix: immutable payload, derived identity, actual payload storage, atomic nonce consumption.
- 06 Test repair: attempt substitution before nonce consumption, then publish the original bytes.

The claim is an API-invariant defect and a repaired experiment, not a vendor exploit.

Reproduce without a live stage dependency.

- 01 make test # gate regression tests; no cloud
- 02 make factory # local committed-fixture logic; no OS containment claim
- 03 make isolated # Linux + bubblewrap; records both experiment suites
- 04 make deck # verify evidence hashes, compile Beamer PDF
- 05 make pptx # editable PowerPoint mirror from the same slide content
- 06 Stage uses the frozen PDF. Optional recorded replay never substitutes for a new execution.

No secrets, live model, Wi-Fi or cloud quota is required to deliver the talk.

Sources and prior work

- 01 Experiment code and evidence: github.com/zozo123/nyc-talk
- 02 Bubblewrap security model: github.com/containers/bubblewrap
- 03 SLSA v1.2: verifying provenance against the actual artifact and expected policy.
- 04 Anthropic, Nov 21, 2025: reward hacking in deliberately vulnerable coding training settings.
- 05 Event: Zenity AI Agent Security Summit, New York, October 21, 2026.

This contribution is the paired, replayable boundary test and its acceptance design.